

Medicare Connect (Pty) Ltd
Vendor Risk Management Policy & Procedure
Aligned to ISO 27001:2022 controls A.5.19 - A.5.22 and POPIA Section 21

Classification : Internal
Version : 1.0
Date : March 2026
Author : Patrick Mohlala , GRC Analyst
Approved By : Pending CEO
Review Date : March 2027

1. Purpose

This policy establishes mandatory requirements for evaluating, onboarding, contracting, and monitoring third-party vendors who process personal information or connect to Medicare connect's clinical network.

2. Scope

Applies to all external suppliers, SaaS providers, cloud host, pathology labs, billing agencies, and IT service providers according to MedicareConnect system or data.

3. Vendor Tiering & Criticality Classification

Tier 1: Critical Risk

- Criteria : Vendor processes special personal information, has direct network access, or provides core clinical systems.
- Assessment Required : full 25 question VSAQ + Evidence validation + Annual re-assessment + Mandatory POPIA Section 21 agreement.
- Sign-off : CEO + Information Officer.

Tier 2 : High Risk

- Criteria : Vendor accesses non-clinical personal information (staff HR data, financial data) or provides critical IT infrastructure without direct data storage.
- Assessment required : standard VSAQ + POPIA section 21 agreement + Bi-annual review.
- Sign-off : Department Manager

Tier 3 : Medium / Low Risk

- Criteria : Vendor processes no personal Information and has no network access
- Assessment required : Basic vendor registration form.
- Sign-off : Department Manager.

4. Vendor Risk Assessment Workflow

Phase 1 : Due diligence and screening

Before signing any contract, Vendor must complete the vendor security Assessment Questionnaire (VSAQ) and provide supporting evidence (e.g ISO 27001 certification, SOC 2 reports, penetration test summaries)

Phase 2 : Risk scoring and Evaluation

The GRC Analyst scores vendor responses across 5 security domains :

1. Governance and Compliance
2. Access control and authentication
3. Data protection and encryption
4. Incident response and Business continuity
5. POPIA operation obligations

Phase 3 : POPIA Contracting

No tier 1 or tier 2 vendor may process data without an executed POPIA section 21 agreement containing mandatory 72 hour breach reporting clauses

Phase 4 : Ongoing monitoring & Audit

Tier 1 vendors undergo annual security reviews. Any material change in vendor architecture or security posture triggers an immediate re-assessment.

5. Minimum Acceptable Security Baseline

Any tier 1 vendor scoring below 70% overall or failing mandatory POPIA requirements must undergo risk treatment before onboarding. Access is prohibited until High-Risk gaps are remediated.

Document Control

Compiled by	: Patrick Vusumuzi Mohlala , GRC Analyst
Version	: 1.0
Status	: Final
Review	: March 2027